

MAC

- ▶ El MAC protege la integridad del mensaje.
- ▶ Un atacante sin la llave no debe poder alterar el mensaje sin que se pueda detectar
- ▶ Mientras la llave se mantenga privada, el MAC provee autenticidad: el receptor sabe que sólo el emisor real pudo enviar el mensaje porque sólo así puede generarse un MAC correcto

HMAC

- ▶ Hash-based Message Authentication Code
- ▶ Es básicamente un hash keyed (no hay un término apropiado en español)
- ▶ Recordar que las funciones de hash son deterministas: dada la misma entrada, siempre se produce la misma salida
- ▶ Cuando un algoritmo es keyed, la salida no depende sólo del contenido de entrada, sino también de la llave

HMAC

- ▶ Para hacer que una función de hash esté keyed es en esencia sencillo
- ▶ Recuerda que las funciones de hash tienen la propiedad de avalancha, basta con agregar la llave al mensaje original para que produzca una salida muy diferente
- ▶ Como con cualquier llave criptográfica, ésta debe ser suficientemente larga y aleatoria para prevenir ataques de diccionario o fuerza bruta

HMAC

$$H(K \oplus opad, H((K \oplus ipad), text)), \text{ donde:}$$

- ▶ H es la función de hash
- ▶ K es la llave que debe cumplir ciertos requisitos
- ▶ $text$ es cualquier binario arbitrario que representa el contenido de entrada
- ▶ $opad$ e $ipad$ son dos valores estáticos que se presentarán más adelante

HMAC

- ▶ De hecho las funciones de hash también trabajan por bloque, por eso funciona la función de update, cada vez que se llama se aplica a cierto número de bloques
- ▶ Una función de hash opera un bloque a la vez y la salida de un bloque se encadena con el cálculo del siguiente bloque
- ▶ Por ejemplo, SHA-1 es de 64 bytes de bloque y SHA-256 es de 128 bytes de bloque

HMAC

En el RFC el tamaño de bloque de H se define como B , estas son las reglas de restricción de K :

1. Si K es más corto que B , entonces a K se le tienen que agregar ceros de padding hasta ser de longitud B
2. Si K es más largo que B , entonces K se reduce aplicando H a K , o sea $H(K)$
3. Si se aplicó 2 y la llave quedó muy corta, entonces se aplica 1

HMAC

- ▶ Si se aplican las reglas anteriores, siempre se va a tener una llave de longitud B
- ▶ En el RFC *ipad* se define como el byte 0x36 repetido B veces
- ▶ *opad* es el byte 0x5c repetido B veces
- ▶ Los pads parecen arbitrarios pero tienen un sentido de seguridad matemático que ayuda a mitigar problemas si los algoritmos de hash son vulnerados (como con MD5 o SHA-1)

HMAC

- ▶ Luego se computa $K \oplus opad$
- ▶ Para obtener el outer-hash final se concatena el resultado de arriba con el resultado del inner-hash y se aplica H
- ▶ El outer-hash es el HMAC de *text* keyed con K

Ejercicio

- ▶ Realiza una implementación manual de HMAC para SHA-256 de acuerdo a la explicación del RFC
- ▶ De acuerdo al tiempo que quede de clase el profesor podría implementar parte del ejercicio

HMAC

```
1 from cryptography.hazmat.backends import default_backend
2 from cryptography.hazmat.primitives import hashes, hmac
3
4 key = b"CorrectHorseBatteryStaple"
5 h = hmac.HMAC(key, hashes.SHA256(), backend=default_backend())
6 h.update(b"hello world")
7 h.finalize().hex() # HMAC en hexadecimal
```

CBC-MAC

- ▶ Similar a AES CBC
- ▶ Recordar que CBC es Cipher Block Chaining
- ▶ Un MAC a menudo es llamado un **tag** (etiqueta) del mensaje
- ▶ Es como una etiqueta que se agrega a un regalo: es información extra que se asocia al contenido principal

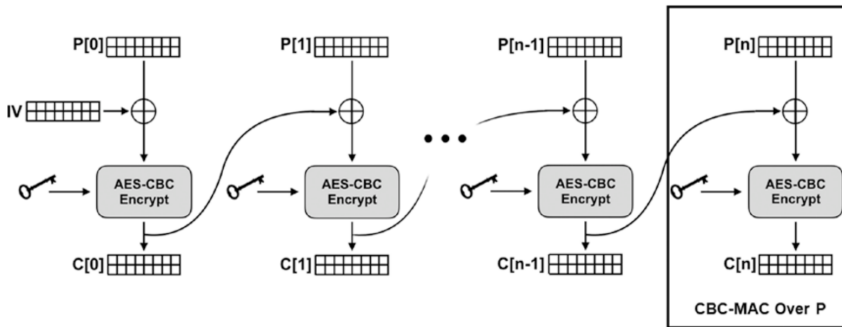
CBC-MAC

- ▶ En notación matemática un tag se denota a menudo como t
- ▶ Así, un MAC sobre un mensaje m_1 produce un tag t_1
- ▶ El par (m_1, t_1) es transmitido al receptor para ser verificado

CBC-MAC

- ▶ En el caso de AES, recuerda que se estaba limitado a cifrar 128 bits de bloque a la vez
- ▶ La idea de AES CBC es encadenar la salida de un bloque cifrado con el siguiente, para que no haya independencia entre bloques y sea más complejo alterar la integridad de los datos
- ▶ Si se alterara un bit en el primer bloque ese cambio crea una cascada de cambios en los bloques siguientes hasta llegar al último bloque
- ▶ Este efecto hace que el último bloque de CBC sea por si mismo un MAC

CBC-MAC



CBC-MAC

- ▶ En esencia CBC-MAC es AES CBC, recuperando el último bloque
- ▶ Pero se deben tomar en cuenta varias consideraciones de seguridad
- ▶ Veamos una implementación no segura

CBC-MAC: ataque antepuesto

- ▶ MAC prepend attack
- ▶ Este ataque funciona con la implementación insegura antes vista
- ▶ La idea básica es que si se tienen dos mensajes M_1 y M_2 y sus tags correspondientes t_1 y t_2 generados con la misma llave k , es posible generar un mensaje nuevo manipulado M_3 cuyo tag t_3 sea igual a t_1 o t_2
- ▶ Osea que es posible mandar un mensaje manipulado y hacer que parezca que es el mensaje M_1 o M_2

CBC-MAC: ataque antepuesto

- ▶ En el ataque M_1 es agregado al inicio de M_2 (o vise-versa), osea es antepuesto
- ▶ M_3 es una mezcla de M_1 y M_2
- ▶ Si el atacante realiza bien el ataque puede crear información falsa, de forma limitada pero con consecuencias prácticas para el atacante
- ▶ El atacante no necesita conocer la llave de MAC

CBC-MAC: ataque antepuesto

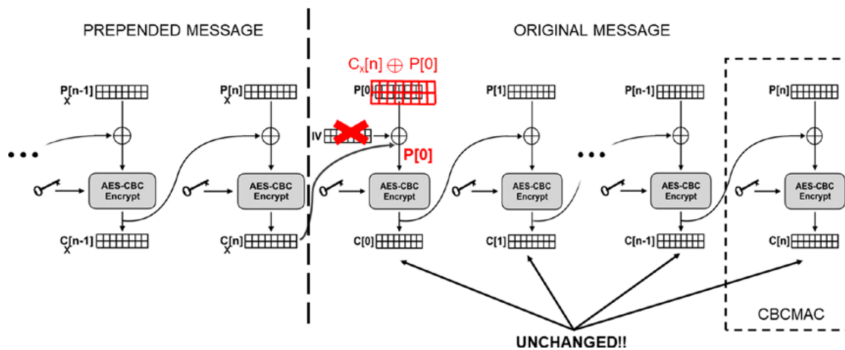
El proceso del ataque es el siguiente (anteponiendo M_1 a M_2):

- ▶ Recuperar el primer bloque de M_2 , denominado M_{2_1} (como es AES se toman los primeros 16 bytes)
- ▶ Recuperar el resto de bloques de M_2 , denominado M_{2_r}
- ▶ Obtener $M'_2 = t_1 \oplus M_{2_1}$
- ▶ $M_3 = M_1 + M'_2 + M_{2_r}$ (+ significa concatenación)
- ▶ Con esto $t_3 = t_2$

CBC-MAC: ataque antepuesto

- ▶ Básicamente lo que hace el ataque es remplazar el primer bloque de M_2 por uno manipulado
- ▶ La víctima verá todo el mensaje M_1 completo (posiblemente con su padding), un bloque que se verá posiblemente corrupto, y el mensaje M_2 sin su primer bloque

CBC-MAC: ataque antepuesto



CBC-MAC: ataque antepuesto

- ▶ Existen muchas soluciones a este ataque
- ▶ Una de ellas es por ejemplo agregar siempre la longitud del mensaje al inicio de éste, de esta manera puede revisarse si se agregó información extra
- ▶ Para hacer una implementación segura se requiere además:
 - ▶ Si además los datos se están cifrando con AES-CBC, no se debe usar la misma llave para cifrar y obtener el MAC
 - ▶ El IV debe ser diferente de cero
- ▶ Lo mejor es utilizar una versión segura estable, por ejemplo CMAC de la biblioteca cryptography que es una versión mejorada de CBC-MAC descrita en el RFC 4493

CBC-MAC

```
1 from cryptography.hazmat.backends import default_backend
2 from cryptography.hazmat.primitives import cmac
3 from cryptography.hazmat.primitives.ciphers import algorithms
4
5 c = cmac.CMAC(algorithms.AES(key), backend=default_backend())
6 c.update(b"message to authenticate")
7 mac = c.finalize()
```

HMAC y CBC-MAC

- ▶ Tanto HMAC como CBC-MAC son buenas opciones para un algoritmo MAC
- ▶ HMAC puede ser más eficiente en la mayoría de sistemas, con excepción de aquellos que tienen hardware especializado para AES
- ▶ Ante la duda, utiliza HMAC

Cifrado y MAC

- ▶ En muchas circunstancias un mensaje necesita ser cifrado y protegido contra modificaciones
- ▶ Si lo analizan, en lo que se vio anteriormente no se especifica si los mensajes para los cuales se derivaba el MAC estaban cifrados o no, en realidad podría ser cualquiera de las dos, los métodos funcionarían igual
- ▶ Pero, si se va a cifrar ¿En qué momento hay que derivar el MAC? ¿Antes o después de cifrar?

Cifrado y MAC

- ▶ Lo que recomienda la mayoría de los criptógrafos (aunque no todos), es utilizar cifra luego aplica MAC (Encrypt-Then-MAC)
- ▶ Algunas vulnerabilidades han sido encontradas para aplica MAC luego cifra (MAC-Then-Encrypt), de hecho por eso ya no se usa en TLS. Por ejemplo el ataque de padding oráculo a CBC sólo funciona con este esquema
- ▶ Cifra luego aplica MAC parece contra-intuitivo, puesto que lo que queremos saber es si los datos originales (texto plano) llegaron bien

Cifrado y MAC

- ▶ Pero considera que tampoco queremos que los datos cifrados sean alterados, de hecho ya hemos visto varios ataques en este sentido
- ▶ Cosas malas pasan si los atacantes pueden cambiar el texto cifrado sin que los receptores se den cuenta
- ▶ Siempre prefiere el esquema de cifra luego aplica MAC
- ▶ En realidad hay algo mejor llamado **AEAD (authenticated encryption with additional data)** que deberías usar en vez de MAC
- ▶ Este esquema integra autenticación e integridad en un cifrado simétrico, se verá en el tema 7

Criptografía asimétrica

- ▶ Se tienen dos llaves: una pública y privada
- ▶ La llave pública se puede derivar de la privada, pero no al revés
- ▶ Si se cifra con la llave pública sólo se puede descifrar con la llave privada y vice-versa
- ▶ La llave privada siempre debe permanecer privada, mientras que la pública está pensada para ser compartida

Firmas digitales

- ▶ Los problemas de integridad y eficiencia son fáciles de solucionar
- ▶ En el modelo explicado, no se está cifrando por confidencialidad, sino por autenticidad
- ▶ En vez de cifrar el mensaje, se puede cifrar un hash del mensaje
- ▶ Esto da tanto integridad como autenticidad
- ▶ Esto es esencialmente una firma digital sobre un mensaje

Firmas digitales

Siguen dos pasas básicos:

- ▶ Calcular el hash del mensaje
- ▶ Cifrar el hash mediante la llave privada

Firmas digitales

- El hash cifrado es la firma digital del emisor
- La firma es transmitida junto con el mensaje (cifrado o no)
- El receptor calcula el hash del mensaje, descifra la firma digital mediante la llave pública y comprueba que los dos hashes coincidan

Firmas digitales

- ▶ Una vez más: el cifrado con la llave pública es para confidencialidad, mientras que el cifrado con la llave privada es para autenticidad
- ▶ A continuación se verá el uso de firmas digitales RSA con la biblioteca cryptography

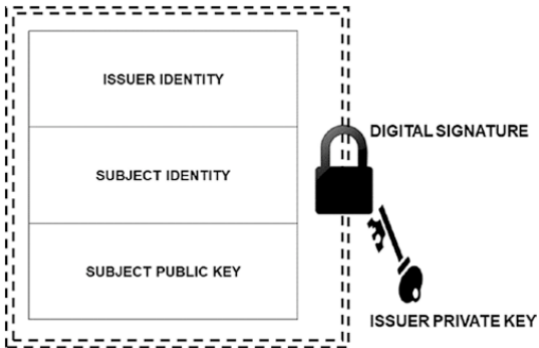
Cifrar y firmar

- ▶ Si tienes que utilizar firmas digitales para un mensaje, lo correcto es firmar luego cifrar, esto es, **se firma el texto plano y luego se cifra tanto el mensaje como la firma**
- ▶ Aunque no existen ataques conocidos para este esquema, los más paranoicos pueden utilizar un esquema: firma luego cifra luego vuelve a firmar
- ▶ Lo anterior te da una firma para la información original y otra para los datos cifrados, con doble autenticación
- ▶ Existen otras técnicas conocidas como singcryption que no se verán en el curso

Certificados

- ▶ En vez de simplemente compartir llaves públicas, lo que se comparte son certificados
- ▶ Si una entidad quiere un certificado:
 - ▶ Genera su par de llaves (la llave privada nunca debe compartirla a nadie, ni a la entidad de confianza)
 - ▶ La entidad de confianza recibe la llave pública y empieza a generar el certificado, incluyendo los metadatos
 - ▶ Para completar el certificado, la entidad de confianza firma el certificado con su llave privada

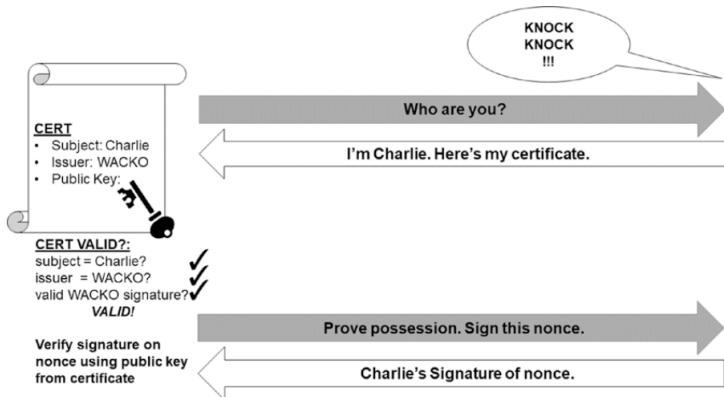
Certificados



Certificados

- ▶ Existe un problema con el modelo visto hasta ahora
- ▶ Imagina que un compañero al que no conoces que se hace llamar Charlie llega y te presenta su certificado, firmado por el profesor en el que confías
- ▶ Podrás, mediante la llave pública del maestro, la cual ya tenías, verificar la firma y sacar la información de identidad, que diga que es de Charlie
- ▶ Pero, ¿Cómo puedes saber que la persona que está ahí realmente es Charlie?
- ▶ Las llaves públicas cualquiera las tiene, alguien pudo haber generado un certificado falso engañando a la entidad de confianza

Certificados



Revocación de certificados

- ▶ Si la llave privada de un certificado generado por un CA se compromete, el CA debe determinar una forma de hacer saber a quienes tienen el certificado ya no es confiable
- ▶ Esto no es tan sencillo
- ▶ Una de las razones para dejar de utilizar un registro global de llaves públicas y usar certificados era poder hacer verificaciones offline
- ▶ ¿Cómo puede un sistema de verificación offline tener información de revocación?

Protección de llaves privadas

- ▶ Debido a lo complicado que es revocar certificados, lo mejor es proteger lo mejor posible las llaves privadas
- ▶ Si no se requieren firmas en tiempo real, las llaves privadas deberían estar en un ambiente seguro offline
- ▶ Si se requieren firmas en tiempo real y que la llave privada esté en un servidor, entonces deben aplicarse permisos mínimos y de preferencia ser cifrados (con cifradores simétricos) con contraseñas fuertes

Ejemplo

- ▶ Aunque el enemigo no pueda alterar el mensaje ni leerlo, puede reenviarlo
- ▶ Esto crea confusión y puede hacer que el enemigo adelante una estrategia

Prevención

- ▶ Algunos sistemas usan un timestamp en vez de nonces aleatorios
- ▶ Con un timestamp el receptor puede rechazar un mensaje que sea demasiado viejo
- ▶ El problema de esta aproximación es que las partes en comunicación deben mantener sus relojes sincronizados, lo cual es más complejo de lo que parece
- ▶ Dado que no es posible tener una sincronización exacta, debido a retraso introducido por diferentes fuentes de latencia (velocidad de red, hops, etc.) el receptor debe aceptar mensajes dentro de una ventana de tiempo para lidiar con el error de tiempo
- ▶ ¿De qué tamaño debe ser la ventana de tiempo? otra vez el atacante puede encontrar patrones explotables

- ◀ ◻ ▶ ◀ ◻ ▶ ◀ ≡ ▶ ◀ ≡ ▶ ≡ ≡